

OWASP ZAP

OVERVIEW:

OWASP ZAP (Zed Attack Proxy) is an open-source web application security testing tool developed by the OWASP Foundation. It is widely used to identify common web vulnerabilities by intercepting, analyzing, and actively scanning HTTP/HTTPS traffic between a browser and a web application.

OWASP ZAP:

It is mainly used for:

- Finding vulnerabilities automatically
- Intercepting and analyzing HTTP/HTTPS traffic
- Scanning web apps for OWASP Top 10 issues

Purpose:

- Identify security vulnerabilities
- Perform automated vulnerability scanning
- Assist manual testing
- Generate professional reports

How OWASP ZAP Works:

OWASP ZAP works as a proxy between:

Browser <—> ZAP Proxy <—> Web Application

Flow:

- Browser sends request
- ZAP intercepts the request
- ZAP analyzes & modifies it (if needed)
- Request goes to the server
- Response comes back via ZAP
- ZAP scans & records vulnerabilities

Tool Used:

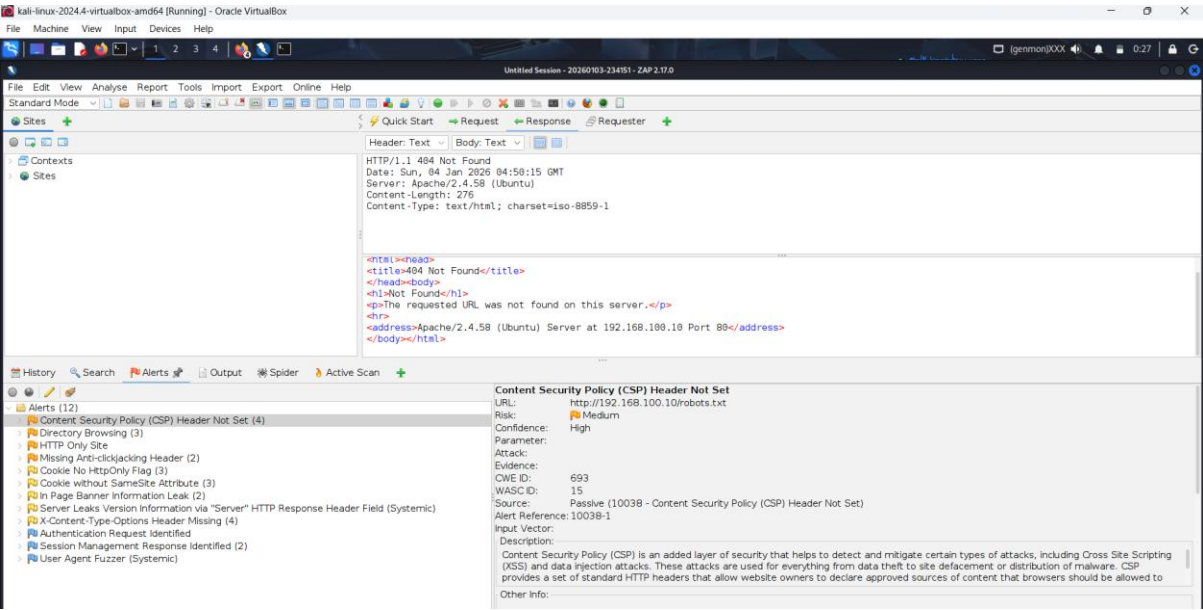
OWASP ZAP (Zed Attack Proxy)

Target Application:

Damn Vulnerable Web Application (DVWA)

URL: <http://192.168.100.10/DVWA>

OWASP ZAP Vulnerability Scan:



Summary of Sequences		
For each step: result (Pass/Fail) - risk (at highest detail for the step, if any).		
Alerts		
Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	4
Directory Browsing	Medium	3
HTTP Only Site	Medium	1
Missing Anti-clickjacking Header	Medium	2
Cookie No HttpOnly Flag	Low	3
Cookie without SameSite Attribute	Low	3
In Page Banner Information Leak	Low	2
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
X-Content-Type-Options Header Missing	Low	4
Authentication Request Identified	Informational	1
Session Management Response Identified	Informational	2
User Agent Fuzzer	Informational	Systemic
Alert Detail		
Medium	Content Security Policy (CSP) Header Not Set	
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.	
URL	http://192.168.100.10/DVWA/index.php	
Node Name	http://192.168.100.10/DVWA/index.php	
Method	GET	

Observation:

- OWASP ZAP is used to scan the target the target web application
- Multiple security issues of varying risk levels were identified
- Alerts were categorized into medium, low, informational risk levels

Impact:

- Allows execution of malicious scripts leading to XSS attacks.
- Attackers can view directory contents and access sensitive files.
- Sensitive data can be intercepted over the network.
- Application is vulnerable to clickjacking attacks.
- Cookies can be stolen using client-side scripts.

- Increases risk of CSRF attacks.
- Helps attackers identify server vulnerabilities

Mitigation:

- Configure a proper Content-Security-Policy header.
- Disable directory listing in the web server configuration.
- Enable HTTPS using SSL/TLS certificates.
- Set the HttpOnly flag on session cookies.
- Hide server version information in HTTP headers.

OWASP Mapping:

A02:2025 – Security Misconfiguration

A04:2025 – Cryptographic Failures

A07:2025 – Authentication Failures

CONCLUSION:

The OWASP ZAP scan revealed that DVWA is vulnerable to multiple OWASP Top 10 risks, mainly due to security misconfigurations and missing security controls. These issues can lead to information disclosure, XSS, session hijacking, and clickjacking attacks.